09 — Risk Yönetimi

Bu doküman MatPortal'ın **teknik**, **iş**, **yasal** ve **güvenlik** risklerini sıralar; her biri için **olasılık × etki** matrisi, **erken sinyaller** ve **mitigation** planı sunar. Risk yönetimi pasif bir liste değil — proje boyunca canlı izlenir.

1. Risk Matrisi — Üst Düzey

```
                    ETKİ
                 Düşük  Orta  Yüksek  Kritik
        Çok Yüksek  •     •      ★       ★★
        Yüksek      •     ★      ★       ★
OLASILIK Orta       •     •      ★       ★
        Düşük       •     •      •       ★
        Çok Düşük   •     •      •       •
```

★ = mitigation şart ★★ = projeyi durdurabilir

2. Teknik Riskler

TR-1: Tahmin modeli düşük doğruluk

- **Olasılık:** Orta
- **Etki:** Yüksek (yöneticinin güveni sarsılır, sistem terk edilir)
- **Erken sinyal:** Faz 2 sonu MAPE > %50 (kabul kriteri %35)
- **Mitigation:**
  1. Naive baseline ile karşılaştır → en azından ondan iyi olsun
  2. Champion/challenger otomatik seçim (Faz 7)
  3. Açıklanabilirlik ile yöneticinin "neden" sorusuna cevap
  4. İlk 3 ay tüm öneriler **manuel onay** — model olgunlaşana kadar
  5. Excel ile geçmiş veri yükleme (Faz 2 + 7) — model zenginleştirme

- **Triger:** MAPE > %35 ise model üretime alınmaz, manuel öneri devam

TR-2: Python ↔ Bun köprü performans sorunu

- **Olasılık:** Düşük
- **Etki:** Orta (latency artışı, kullanıcı şikayeti)
- **Erken sinyal:** Tahmin endpoint p95 > 2s
- **Mitigation:**
  1. Redis cache (1 saat TTL) — tekrar sorgular cache'ten
  2. Batch tahmin (toplu çağrı) — tek tek değil
  3. Async queue (BullMQ) — kritik olmayan tahminler
  4. Python servis horizontal scale (3+ instance, load balancer)
- **Triger:** p95 > 1s sürekli → ek instance veya ML servis ayrı sunucu

TR-3: Bayi siteleri scraping engelliyor (Cloudflare, captcha)

- **Olasılık:** Yüksek
- **Etki:** Orta (Faz 5 etkilenir, alternatif sinyaller var)
- **Erken sinyal:** Crawl başarı oranı < %70
- **Mitigation:**
  1. playwright-extra + stealth plugin (sınırlı, public veri için)
  2. Bright Data residential proxy (gerçek IP)
  3. Apify managed scraper (sosyal medya)
  4. Alternative: bayi sözleşmesinde "izin verilmiş" klozu (etik)
  5. Manuel sinyal girişi (saha ekibi telefon eder, "kapalı/açık")
  6. Alternatif veri kaynakları (sanayim.net, Google Maps yorumları)
- **Triger:** Scraping başarı < %70 ise plan B (Apify + manuel)

TR-4: LLM API kesintisi / rate limit

- **Olasılık:** Orta
- **Etki:** Orta (sohbet ve açıklama etkilenir, kritik değil)
- **Erken sinyal:** API hata oranı > %5
- **Mitigation:**
  1. Multi-provider: Claude → OpenAI → Groq fallback

2. Cache (LLM sonucu deterministik prompt için 24 saat)
3. Graceful degradation: LLM yoksa “açıklama mevcut değil” göster
4. Kritik aksiyonlar LLM’e bağımlı değil (istatistiksel öncelikli)

- **Triger:** Provider kesintisi → otomatik switch + bildirim

TR-5: MySQL ölçek sorunu (100K+ kayıt)

- **Olasılık:** Düşük (yıl 1)
- **Etki:** Yüksek (sistem yavaşlar)
- **Erken sinyal:** Slow query log artışı, p99 > 1s
- **Mitigation:**
  1. Index stratejisi her sorgu pattern’ine göre
  2. Read replica (raporlama yükü ana DB’yi etkilemesin)
  3. Materialized view: `bayi_aylik_ozet` gibi denormalize
  4. Partitioning: `tahmin_calistirma`, `web_kazima_kayitlari` tarih bazlı
  5. Redis cache layer
- **Triger:** Slow query > %10 → optimize + replica

TR-6: Excel upload kötü veri (1000 satır outlier)

- **Olasılık:** Yüksek
- **Etki:** Orta (model bozulur, geri alma gerekli)
- **Erken sinyal:** Yükleme sonrası MAPE düşüşü > %20
- **Mitigation:**
  1. Outlier auto-flag (IQR × 3 üstü)
  2. Preview + manuel onay zorunlu
  3. Yükleme öncesi snapshot (rollback hazır)
  4. Champion/challenger A/B (eski model paralel test)
  5. Auto-rollback (MAPE %50 üstü → eski sürüm)
- **Triger:** A/B test’te challenger %20 kötü → reddedilir

TR-7: Multi-deployment kod kayması (gizli SaaS riski)

- **Olasılık:** Düşük

- **Etki:** Yüksek (Promats farklı müşteriden bug yaşarsa “kim diğer müşteri?”)
- **Erken sinyal:** Müşteriye-özel hardcode artışı
- **Mitigation:**
  1. Tek codebase (matportal-core repo)
  2. Müşteri-özel ayarlar **env** + **konfig JSON**
  3. Müşteri-özel branch’ler yasak; her şey trunk’ta
  4. Müşteri ayrımı için sadece deployment seviyesinde (DB, env)
  5. Promats için kullanılan repo → private + ayrı acces
- **Triger:** Branch divergence görülürse merge

TR-8: Test coverage düşüşü

- **Olasılık:** Orta
- **Etki:** Orta (regresyon bug’ları, prod’da fark edilir)
- **Erken sinyal:** Coverage < %70
- **Mitigation:**
  1. PR template’inde “test eklendi mi” checkbox
  2. Coverage gate: %70 altı PR merge olmaz (CI)
  3. Kritik fonksiyonlar (auth, sipariş) %90+ zorunlu
  4. E2E smoke test deploy sonrası
- **Triger:** Coverage 2 ay ardarda düşerse: dedicated test sprint

3. İş & Operasyonel Riskler

IR-1: Bayi portal’ı kullanmıyor (adapt sorunu)

- **Olasılık:** Yüksek (alışkanlık)
- **Etki:** Yüksek (Faz 6 değer üretmez)
- **Erken sinyal:** Pilot bayilerin %50’si 2 hafta sonra giriş yapmıyor
- **Mitigation:**
  1. Pilot 5 bayi ile başla (yönetilebilir)
  2. Onboarding: canlı eğitim + video + saha desteği
  3. WhatsApp/telefon kanalı **paralel açık** kalır

4. Yönetici “portalda sipariş ver, %3 ek iskonto” teşviki
5. Bayinin kendi ekibinin portal’a alıştırılması (admin → operatör)
6. UX iterasyon: pilot feedback → 2 haftada bir UI güncelleme

- **Triger:** Pilot feedback olumsuzsa: 2 hafta süre uzatılır, UX revizyonu

IR-2: Yönetici AI önerisine güvenmiyor

- **Olasılık:** Yüksek (yeni teknoloji)
- **Etki:** Orta (Faz 7-8 değer azalır)
- **Erken sinyal:** Yöneticinin %80+ AI önerisini reddediyor
- **Mitigation:**
  1. İlk 3 ay manuel onay zorunlu (öğrenme dönemi)
  2. Açıklanabilirlik: “neden bu öneri” doğal dilde
  3. Geri bildirim döngüsü: red sebebi kayıt, model öğrensin
  4. Naive baseline ile karşılaştırma: “AI seninle aynı kararı verdi” güven inşa eder
  5. Risk skorlu eşik: yüksek risk → her zaman manuel
  6. Audit + rollback: hata olursa anında geri alınır
- **Triger:** Red oranı > %50 → eşik yükselt, prompt iyileştir

IR-3: Promats yönetiminde değişiklik (sponsor kaybı)

- **Olasılık:** Düşük
- **Etki:** Kritik
- **Erken sinyal:** Yönetim toplantısı katılımı azalması, karar gecikmeleri
- **Mitigation:**
  1. Faz tamamlanmasıyla milestone belge teslim (her şey kayıtlı)
  2. Düzenli demo + raporlama (her 2 hafta)
  3. ROI metrikleri sürekli görünür
  4. Tek kişiye bağımlı olmayan onay süreci
  5. Yönetici eğitimi: en az 2 kişi sistemi tanır
- **Triger:** 2 demo arka arkaya iptal → eskalasyon

IR-4: Kapsam genişliği yönetilemez (scope creep)

- **Olasılık:** Yüksek
- **Etki:** Yüksek (zaman+bütçe taşar)
- **Erken sinyal:** “Bunu da ekleyebilir misin” sıklığı haftada 2+
- **Mitigation:**
  1. 11 fazlı net plan, her faz **tek başına çalışır**
  2. Yeni istek → “hangi faza ait, hangi mevcut özellik kesilir” karşılığı
  3. Backlog: yeni istekler **Faz 10+** olarak kaydedilir
  4. Pazarlık: müşteri zorlarsa kapsam değil takvim genişler
  5. Aylık değerlendirme: yapılanlar + yapılmayanlar + öncelik revizyonu
- **Triger:** Faz X tahmini süreden %20 uzun → durdur, gözden geçir

IR-5: Personel kaybı (kilit dev ayrılır)

- **Olasılık:** Orta
- **Etki:** Yüksek (bilgi kaybı, yavaşlama)
- **Erken sinyal:** Tükenmişlik sinyalleri, gecikmeler
- **Mitigation:**
  1. Kod review + dokümantasyon (CLAUDE.md güncel)
  2. En az 2 kişi her modülü biliyor (knowledge sharing)
  3. Backup developer (yarı zamanlı destek)
  4. Tartışma dokümanları (mimari kararlar yazılı)
  5. Bus factor metriği: tek kişiye bağımlı modül azaltılır
- **Triger:** Geliştirici 1 ay tatil/izin → yedek hazır

IR-6: Veri kalitesi düşük (eksik/yanlış kayıtlar)

- **Olasılık:** Yüksek
- **Etki:** Orta (model hatalı)
- **Erken sinyal:** Veri profil raporu — null %, outlier %, duplicate %
- **Mitigation:**
  1. Faz 0’da veri zenginleştirme (manuel + AI destekli)
  2. Validation rule’ları: zorunlu alanlar, format
  3. Veri kalite dashboard: yöneticiye haftalık rapor
  4. Outlier auto-flag (eğitim verisinden çıkarılır)

5. Yönetici düzeltme aksiyonu kayıtlı

- **Triger:** Null oran %20+ → veri temizleme sprint

IR-7: Pilot bayiler temsili değil

- **Olasılık:** Orta
- **Etki:** Orta (canlıda farklı sorunlar)
- **Erken sinyal:** Pilot %100 başarılı ama daha geniş kullanım sorunlar
- **Mitigation:**
  1. Pilot bayi seçimi: 3 farklı segment (büyük/orta/küçük) + 2 farklı bölge
  2. Pilot süresi 4 hafta minimum
  3. Kademeli yaygınlaştırma (5 → 10 → 25)
  4. Her aşamada feedback toplama
  5. Geri çekilme prosedürü (Plan B hazır)
- **Triger:** Yaygın canlıda kritik bug: kademeli rollback

4. Yasal & Compliance Riskleri

YR-1: KVKK uyumsuzluk (kişisel veri)

- **Olasılık:** Orta
- **Etki:** Kritik (ceza, operasyon durması)
- **Erken sinyal:** Bayi şikayeti, yasal uyarı
- **Mitigation:**
  1. KVKK aydınlatma metni (Faz 5 başı yazılı)
  2. Bayi sözleşmesinde scraping klozu (yazılı izin)
  3. Sadece **firma verisi** topluyoruz (kişisel değil)
  4. Telefon/email PII alanları erişim audit'li
  5. Silme talebi flow'u (KVKK madde 11 uyumlu)
  6. Avukat danışmanlığı (Faz 5 başı + yıllık)
- **Triger:** Resmi KVKK uyarı → 30 gün içinde uyum

YR-2: GDPR (yurt dışı bayi)

- **Olasılık:** Düşük (Faz 3 sonrası)
- **Etki:** Yüksek (AB pazarı kapanır)
- **Erken sinyal:** AB lead'lerden veri silme talebi
- **Mitigation:**
  1. Apollo.io / Cognism GDPR-uyumlu provider
  2. Veri saklama AB sınırı içinde (S3 EU region)
  3. "Right to be forgotten" otomatik flow
  4. Cookie banner (portal AB ziyaretçiye)
- **Triger:** GDPR şikayet → veri silme + uyum güncelleme

YR-3: Web scraping ToS ihlali

- **Olasılık:** Yüksek (siteler değişir)
- **Etki:** Orta (yasal risk düşük, hesap kapanması orta)
- **Erken sinyal:** Site User-Agent ban, 403 errors
- **Mitigation:**
  1. robots.txt'e saygı (otomatik kontrol)
  2. Açık User-Agent (`MatPortalBot/1.0`)
  3. Rate limit (1 req / 2s / domain)
  4. LinkedIn yasak (ToS kesin)
  5. Apify ile sosyal medya (managed, ToS uyumlu)
  6. Avukat görüşü (toplam scraping politikası)
- **Triger:** Site ban → o site listeden çıkar

YR-4: e-Fatura / vergi mevzuatı değişiklikleri

- **Olasılık:** Yüksek (Türkiye mevzuatı sık değişir)
- **Etki:** Orta (entegrasyon güncellemesi)
- **Erken sinyal:** GİB duyuru
- **Mitigation:**
  1. Mevcut e-Fatura sağlayıcı (Logo/Mikro) abstraction
  2. Mevzuat takip listesi
  3. Hızlı güncelleme prosedürü
- **Triger:** Mevzuat değişikliği → 30 gün içinde uyum

YR-5: CBAM (AB Karbon Sınır Vergisi)

- **Olasılık:** Yüksek (2026'dan itibaren yürürlükte)
- **Etki:** Orta (ihracat müşterisi raporu istiyor)
- **Erken sinyal:** AB müşteri raporu talep
- **Mitigation:**
  1. Faz 10+ Sürdürülebilirlik modülü hazır
  2. LCA (Life Cycle Assessment) altyapısı
  3. Karbon ayakizi raporu (PDF) müşteriye otomatik
- **Triger:** İlk AB müşteri talebi → modül acil aktivasyon

5. Güvenlik Riskleri

GR-1: Authentication zafiyeti (brute force)

- **Olasılık:** Yüksek (her sistem hedef)
- **Etki:** Yüksek (bayi hesap çalınması)
- **Erken sinyal:** Login attempt logları, başarısız oran
- **Mitigation:**
  1. Rate limit: 5 deneme/dk + 30 dk kilit
  2. CAPTCHA (3 başarısız sonrası)
  3. 2FA (Faz 6 v2)
  4. Şifre policy: min 10 karakter + complexity
  5. Login alarm (yöneticiye email — şüpheli IP)
  6. Sentry alarm: brute force pattern
- **Triger:** 1 saat içinde 100+ başarısız login → IP ban

GR-2: SQL injection / XSS

- **Olasılık:** Düşük (Drizzle ORM + React)
- **Etki:** Kritik
- **Erken sinyal:** Penetration test bulguları
- **Mitigation:**
  1. Drizzle ORM parametreli sorgu (raw SQL yasak)

2. React 19 default escape
3. Content Security Policy (CSP)
4. Input validation (Zod schema)
5. Pen test yıllık

- **Triger:** Bulgu → 24 saat içinde fix

GR-3: Secret leak (API key Git'e commit)

- **Olasılık:** Orta (insan hatası)
- **Etki:** Yüksek
- **Erken sinyal:** GitHub secret scanning alarm
- **Mitigation:**
  1. `.env` Git ignore
  2. `.env.example` template (gerçek key yok)
  3. Pre-commit hook: secret pattern tarama
  4. GitHub Advanced Security
  5. Secret rotation prosedürü (compromise sonrası)
- **Triger:** Secret leak → anında rotate

GR-4: LLM prompt injection

- **Olasılık:** Orta
- **Etki:** Orta (yanlış aksiyon)
- **Erken sinyal:** Anormal aksiyon önerisi, audit log
- **Mitigation:**
  1. Kullanıcı girdisi `<user>...</user>` tag içinde
  2. System prompt sabit + kullanıcı girdiden ayrı
  3. Risk skoru → kritik aksiyon her zaman insan onayı
  4. Aksiyon limit: tek mesajda max 1 aksiyon
  5. Audit log + rollback
- **Triger:** Şüpheli payload → rule-based block

GR-5: DDoS saldırısı

- **Olasılık:** Düşük
- **Etki:** Yüksek (sistem erişilemez)
- **Erken sinyal:** Trafik spike + 5xx oranı artışı
- **Mitigation:**
  1. Cloudflare proxy (DDoS protection ücretsiz tier)
  2. Rate limit per-IP (Redis)
  3. WAF (Web Application Firewall)
  4. CDN (statik asset)
  5. Auto-scaling (yüksek trafik bypass)
- **Triger:** DDoS pattern → Cloudflare “Under Attack” mode

GR-6: Veri ihlali (data breach)

- **Olasılık:** Düşük
- **Etki:** Kritik
- **Erken sinyal:** Anormal DB query, dış erişim
- **Mitigation:**
  1. Database encryption at rest (LUKS)
  2. TLS 1.3 in transit
  3. PII minimization (sadece gerekli)
  4. Access audit (kim ne zaman ne sorguladı)
  5. Backup encryption
  6. Penetration test
- **Triger:** Breach tespit → 72 saat KVKK bildirim (yasal)

6. Risk Toplama ve Gözlem

6.1 Risk register

Tüm riskler tek tabloda canlı tutulur:

```
CREATE TABLE risk_register (
  id char(36) PK,
  kod varchar(16),                  -- 'TR-1', 'IR-3' gibi
  baslik varchar(255),
  kategori ENUM('teknik','is','yasal','guvenlik'),
  olasilik ENUM('cok_dusuk','dusuk','orta','yuksek','cok_yuksek'),
  etki ENUM('dusuk','orta','yuksek','kritik'),
  durum ENUM('aktif','azaltildi','kapandi','kabul_edildi'),
  mitigation text,
  sahip_user_id char(36),
  son_inceleme datetime,
  created_at datetime
);
```

6.2 Aylık risk değerlendirmesi

- Tüm aktif riskler gözden geçirilir
- Yeni riskler eklenir
- Olasılık × etki güncellenir
- Mitigation etkinliği değerlendirilir
- Promats yönetimi raporu

6.3 Risk dashboard

```
[Ekran: /admin/risk-dashboard]
  Aktif risk sayısı: 23
  ├─ Kritik: 2 (mitigation %80 hazır)
  ├─ Yüksek: 8
  ├─ Orta: 9
  └─ Düşük: 4

  Bu ay açılan: 3
  Bu ay kapanan: 5
  Üst-yönetim dikkat gereken: TR-1, IR-3
```

7. Acil Durum Prosedürleri

7.1 Sistem çökmesi (downtime)

```
1. Sentry alarm
2. On-call dev dashboard'u kontrol
3. < 15 dk: rollback son stable deploy
4. > 15 dk: yedek VPS'te restore (DR prosedürü)
5. Status page güncelleme
6. Post-mortem 24 saat içinde
```

7.2 Veri ihlali (suspected breach)

```
1. Log incele, etkilenen data sınırla
2. Sistemi izole et (gerekiyorsa tüm sessions kill)
3. KVKK bildirim (72 saat — yasal)
4. Etkilenen müşteri bildirim
5. Avukat + güvenlik danışmanı
6. Forensic analysis
7. Public disclosure (gerekirse)
```

7.3 Yasal tebligat (KVKK / GDPR)

```
1. Avukat anında bilgilendir
2. 30 gün içinde uyum action plan
3. İlgili veri pause (silme/saklama askıya)
4. Müşteriye proaktif iletişim
```

7.4 LLM provider çökmesi

```
1. Auto-fallback (Claude → OpenAI → Groq)
2. Eğer hepsi çökmüş: AI özellikleri devre dışı, klasik UI
3. Sentry alarm + Twitter/status takibi
4. Provider haber gelene kadar bekle
```

8. Risk Kabul Eşikleri

Her risk için “kabul edilebilir maksimum” tanımlanır:

Risk	Maks kabul edilebilir
Tahmin MAPE	%35 (ilk 6 ay), %20 (yıl 1)
API uptime	%99.5 (4.4 saat downtime/ay)
Sipariş hatası	<%2 (önce %80 azalış)
Veri kayıp	1 saat veri (saatlik binlog)
Login başarısızlık	<%5 normal user
LLM bütçe aşımı	%0 (kill-switch %100'de)
KVKK uyum	%100 (tolerans yok)
Pen test bulgu kritik	0 (24 saat fix)

9. Açık karar noktaları (Risk)

1. **Risk register'ı kim yönetir:** Tek dev mi, dedicated PM mi? (Önerim: Tech Lead, aylık review)
2. **Pen test sıklığı:** Yıllık mı, 6 ayda bir mi? (Önerim: ilk yıl 2 kez, sonra yıllık)
3. **DR test:** Hiç mi, yılda bir mi? (Önerim: 6 ayda bir tatbikat)
4. **Sigorta:** Siber sigorta gerekli mi? (Önerim: Yıl 2'de değerlendir, müşteri sayısı arttığında)
5. **Avukat:** Sürekli retainer mı, ihtiyaç anında mı? (Önerim: yıllık retainer, ufak danışmanlık)
6. **Risk eşalasyon:** Hangi risk Promats yönetimine bildirilir? (Önerim: olasılık × etki = 12+)
7. **Bug bounty:** Açık veya özel program mı? (Önerim: Yıl 2+ özel — düşük öncelik)
8. **Compliance audit:** Yıllık dış denetim mi? (Önerim: ilk yıl iç, sonra dış)
9. **Insurance:** Genel sorumluluk + siber? (Önerim: Yıl 2)
10. **Risk dashboard:** Her hafta yöneticiye email mi? (Önerim: aylık özet, kritik risk anında)